

Contents

1 ARB Submission Package – Executive Summary 1

1.1 1. Initiative Overview 1

1.1.1 M&T Bank Technology Stack Alignment 1

1.1.2 Business Justification 2

1.2 2. Architecture Summary 2

1.2.1 System Layers 2

1.2.2 Key Technology Choices 2

1.3 3. Regulatory Compliance Summary 3

1.3.1 GENIUS Act Compliance (Sections 4-8) 3

1.3.2 Additional Regulatory Coverage 3

1.4 4. Risk Assessment 4

1.4.1 Top Risks and Mitigations 4

1.4.2 Control Effectiveness 4

1.5 5. Security Architecture 5

1.5.1 Key Management 5

1.5.2 Signing Policy 5

1.5.3 Custody Tiering 5

1.6 6. Examiner Transparency 5

1.7 7. ARB Decision Requested 5

1.8 8. Package Contents 5

1 ARB Submission Package – Executive Summary

M&T Bank | Cari Deposit Account (CDA) Platform on Cari Network Architecture Review Board Submission
Date: March 2026 | Version: 1.0 Sponsor: Matt McAfee, Head of Digital Assets Classification: CONFIDENTIAL
– ARB Internal Review

1.1 1. Initiative Overview

M&T Bank proposes to launch FDIC-insured Cari Deposit Accounts (CDA) on the Cari Network, a permissioned blockchain built on ZKsync Prividium (zkRollup Layer 2). This initiative enables M&T to offer programmable, instantly-settleable bank deposits to institutional and commercial clients, with full GENIUS Act compliance, FDIC insurance coverage, and OCC examiner transparency.

The platform implements a **dual-rail architecture** where CDA tokens (on-chain) operate in parallel with traditional Demand Deposit Accounts (DDA) off-chain, with the **Operator** (M&T Bank) controlling CDA supply through mint/burn operations, and the **Settlement Bank** executing daily net settlement of inter-bank CDA transfers via the **Messaging Bridge**.

1.1.1 M&T Bank Technology Stack Alignment

Component	Technology	Purpose
Core Banking	Hogan mainframe (IBM Z)	CIF/DDA ledger, GL posting, payment processing
Middleware	IBM Z Data Integration Hub (DIH)	JSON/REST to COBOL copybook translation
Event Bus	Kafka (Confluent Platform, KRaft mode)	Real-time event streaming between services
Compute	Azure AKS	Kubernetes orchestration for microservices

Component	Technology	Purpose
Container Registry	Azure ACR (mtbcari.azurecr.io)	Docker image storage and scanning
Key Management GL Format	Azure Managed HSM / Azure Key Vault Post-2025 GL (ISO 20022 aligned)	FIPS 140-2 L3 key storage Hogan GL subsystem integration
Payment Rails	ACH, Fedwire, RTP/FedNow	Fiat settlement via Hogan payment processing

1.1.2 Business Justification

Driver	Detail
Market Opportunity	\$2.1T tokenized asset market by 2030 (BCG estimate); M&T targets \$500M-\$1B CDA AUC by 2028
Competitive Pressure	JPMorgan Kinexys operational; Goldman/BNY on Canton Network; regional bank opportunity closing
Revenue Potential	\$7-23M annual value by Year 3 from settlement efficiency, new products, reduced ops costs
Strategic Positioning	M&T is a Cari Network founding partner; first-mover advantage among regional banks
Regulatory Timing	GENIUS Act advancing; early compliance demonstrates regulatory leadership

1.2 2. Architecture Summary

1.2.1 System Layers

Layer	Technology	Status	Test Coverage
Layer 1: On-Chain Contracts	Solidity on ZKsync Prividium	Complete	104/104 tests
Layer 2: Off-Chain Orchestration	Python FastAPI	Complete	57/57 tests
Layer 3: Security & Compliance	Python + HSM abstraction	Complete	62/62 tests
Layer 4: Executive & Deployment	CI/CD + Helm + monitoring	Complete	Verified
Total		All layers operational	223/223 tests

1.2.2 Key Technology Choices

Decision	Choice	Rationale
Blockchain L2	ZKsync Prividium	Cari Network standard; ZK-proof privacy; EVM equivalent

Decision	Choice	Rationale
Smart Contract Standard	ERC-20 CDA + UUPS Proxy	Upgradeable; compliance hooks; pause capability
Supply Control	Operator Role	M&T Bank as centralized CDA supply controller (mint/burn)
Settlement	Settlement Bank + Daily Net Settlement	Aggregates and nets inter-bank CDA transfers per window
Cross-Bank Comms	Messaging Bridge	Cross-chain/cross-bank CDA transfer communication
Core Banking	Hogan mainframe (IBM Z)	Proven CIF/DDA ledger; post-2025 GL format; Hogan payment processing
Middleware	IBM Z DIH	JSON/REST gateway to Hogan COBOL copybooks; MQ integration
Off-Chain Framework	FastAPI (Python)	Async performance; Pydantic validation; M&T team familiarity
Container Platform	Azure AKS	M&T standard; native Azure integration; RBAC
Container Registry	Azure ACR (mtbcari.azurecr.io)	Private registry; vulnerability scanning; geo-replication
Custody	Fireblocks MPC (primary)	SOC 2 Type II; 1800+ institutional clients; MPC-CMP
AML/OFAC	Chainalysis KYT	Regulatory gold standard; M&T existing relationship
Travel Rule	Notabene	Market-leading VASP directory; FinCEN compliant
Key Management	Azure Managed HSM	FIPS 140-2 Level 3; key material never exposed
Event Bus	Kafka (Confluent KRaft)	High-throughput event streaming; M&T standard

1.3 3. Regulatory Compliance Summary

1.3.1 GENIUS Act Compliance (Sections 4-8)

Section	Requirement	Implementation	Status
S4	1:1 Reserve Backing	On-chain enforcement + cryptographic proof engine	COMPLIANT
S5	Redemption at Par	CDA burn-to-redeem flow with immediate DDA payout	COMPLIANT
S6	Monthly Reserve Attestation	Automated attestation with staleness detection (72h)	COMPLIANT
S7	Disclosure Obligations	Examiner dashboard with CSV export	COMPLIANT
S8	Insolvency Priority	Smart contract pause + emergency CDA burn capability	COMPLIANT

1.3.2 Additional Regulatory Coverage

Framework	Controls	Implementation	Test Pass Rate
NYDFS 23 NYCRR 500	8 controls (500.02-500.17)	100% implemented	100%
BSA/AML/OFAC	3 controls	100% implemented	100%
FinCEN Travel Rule	\$3,000 threshold	SHA-256 PII hashing + Notabene VASP	100%

Total: 16 regulatory controls | 100% implementation | 100% test coverage | 92.5% avg effectiveness

1.4 4. Risk Assessment

1.4.1 Top Risks and Mitigations

#	Risk	Inherent Level	Residual Level	Primary Control
1	Private key compromise	CRITICAL	LOW	HSM isolation + MPC + rotation policy
2	CDA reserve backing breach	CRITICAL	LOW	On-chain enforcement + real-time monitoring
3	OFAC sanctions violation	HIGH	LOW	Real-time Chainalysis screening + batch
4	Smart contract vulnerability	HIGH	MEDIUM	Audit + formal verification + pause
5	Travel Rule non-compliance	HIGH	LOW	Automated \$3K threshold + Notabene
6	Operational disruption	MEDIUM	LOW	DR playbooks (5-30 min RTO) + circuit breakers
7	Data breach	HIGH	LOW	Encryption at rest + in transit + HSM
8	Third-party vendor failure	MEDIUM	LOW	Dual custody providers + fallback screening

1.4.2 Control Effectiveness

- **8 baseline risks** tracked in risk matrix with inherent/residual scoring
- **16 regulatory controls** mapped to specific frameworks
- **4 DR playbooks** with tested recovery procedures
- **Circuit breaker pattern** for automatic failover

1.5 5. Security Architecture

1.5.1 Key Management

- **9 isolated key roles:** MINTER, BURNER, ATTESTOR, COMPLIANCE, SETTLEMENT, PAUSER, UPGRADER, ADMIN, OPERATOR
- **HSM-backed:** Private keys never leave hardware security boundary
- **Dual control:** Key destruction requires 2+ authorized approvals
- **Automated rotation:** 90-day rotation policy with quorum enforcement

1.5.2 Signing Policy

- **Risk-tiered approvals:** 1 approval (<\$10K), 2 approvals (\$10K-\$1M), 3 approvals (>\$1M)
- **Time-locks:** 1-hour lock for HIGH risk, 24-hour for CRITICAL (>\$10M)
- **Self-approval prohibition:** No signer can approve their own request
- **Immutable audit trail:** Every action logged with timestamp, actor, and outcome

1.5.3 Custody Tiering

- **Hot wallet:** <\$500K, immediate operations
 - **Warm wallet:** \$500K-\$10M, approval-gated
 - **Cold wallet:** >\$10M, multi-sig + time-lock
-

1.6 6. Examiner Transparency

The platform provides full transparency to OCC, Fed, and NYDFS examiners:

Capability	Access Method
Real-time CDA reserve backing ratio	API endpoint + dashboard
CDA transaction audit trail	API endpoint + CSV export
Control effectiveness metrics	Dashboard + scheduled reports
AML screening results	Searchable audit log
Incident history	Incident response log + regulatory notifications
Risk register	Live risk matrix with residual scoring
Dual-rail reconciliation	CDA vs DDA matching summary

1.7 7. ARB Decision Requested

Approval Type: Conditional Approval for Pilot Phase

Conditions for Full Approval: 1. Independent security audit (Trail of Bits or equivalent) with all CRITICAL findings remediated 2. Fireblocks enterprise agreement executed 3. Chainalysis KYT extended to cover Cari Network addresses 4. UAT sign-off from M&T Treasury Operations 5. OCC Activity Letter filed with no objection received

Recommendation: APPROVE WITH CONDITIONS

1.8 8. Package Contents

This ARB submission includes the following documents:

Document	Location
This Executive Summary	arb_package/executive_summary.md
Target-State Architecture	arb_package/architecture_target_state.md
Transitional Architecture	arb_package/architecture_transitional.md
End-to-End Transaction Flows	arb_package/end_to_end_flows.md
Risk & Compliance Matrix	arb_package/risk_compliance_matrix.md
Control Implementation Evidence	arb_package/control_evidence.md
Examiner Transparency Artifacts	arb_package/examiner_transparency.md
Vendor Evaluation Matrix	strategic/vendor_matrix.md
Emerging Technology Assessment	strategic/emerging_tech_assessment.md
Production Roadmap	strategic/roadmap.md
Executive Strategy Memo	strategic/executive_memo.md
Deployment & Operations	deployment/
Board Presentation	final/board_presentation.md

Submitted by: StableArch Council – Architecture Review Board M&T Bank | Cari Network CDA Platform | ZKsync Prividium